Exercise 6

Ex. No.: 6

Enumerate Web Server Information

Aim:

To perform web server enumeration and gather detailed information about a target server,

including DNS records, technologies, open ports, services, and potential vulnerabilities. Web server

enumeration is a crucial step in the cybersecurity assessment process. It involves gathering

information about a target web server, such as its operating system, web server software, installed

applications, and potential vulnerabilities.

Procedure:

To identify and enumerate web server information such as technologies, headers, and potential

security misconfigurations using OWASP ZAP.

OWASP ZAP (Zed Attack Proxy) – GUI or CLI

A test website (example: `http://testphp.vulnweb.com` or DVWA in XAMPP/Kali Lab)

Step 1: Start OWASP ZAP

Open ZAP on your system.

Set your browser to use ZAP as a proxy (default: `127.0.0.1:8080`).

This ensures all HTTP/HTTPS traffic goes through ZAP.

Step 2: Access Target Website

Open browser → Visit target site (e.g., `http://testphp.vulnweb.com`).

ZAP will start capturing the requests and responses in the Sites tree.

Step 3: Basic Information Gathering

In ZAP, right-click the target → "Open/Resend with Request Editor" or check the HTTP response

headers.

Look for:

Server Header → Apache/Nginx/IIS with version

X-Powered-By → PHP/ASP.NET version

Set-Cookie → Session management details

Content-Type → MIME type info

Step 4: Use the Spider Tool

In ZAP, right-click target → Attack → Spider.

It will crawl the site, enumerate directories, parameters, and links.

Helps identify hidden pages or services.

Step 5: Use the Active Scan

Right-click target → Attack → Active Scan.

Select scope and start scan.

ZAP will try to detect:

Vulnerable HTTP methods (`TRACE`, `PUT`, `OPTIONS`)

SSL/TLS misconfigurations

Security headers missing (HSTS, CSP, X-Frame-Options)

Cookies without secure/httponly flags

Step 6: Check Technology Fingerprinting

Go to Sites Tree → Technology Tab.

ZAP will automatically fingerprint:

Web server software

Scripting language (PHP, JSP, ASP.NET)

- Frameworks (WordPress, Joomla, Drupal, etc.)

Step 7: Generate a Report

File → Generate Report → Select HTML/PDF.

Report includes:

- Enumerated web server details
- Security misconfigurations
- Vulnerabilities found

Expected Outcome

From ZAP enumeration, you will get:

Web server type & version (e.g., Apache 2.4.29, Nginx 1.18)

Programming language & framework (PHP, ASP.NET, WordPress, etc.)

Security headers present/missing (HSTS, CSP, X-Content-Type-Options)

Cookies details (Secure/HttpOnly flags)

SSL/TLS weaknesses

Exposed directories/pages